Référentiel de sécurité et responsabilités

AGR-1480 / CYBER-G1
Gridone 0.307.0 - Produit et déploiement sur un site client type

Ce dossier établit une base de contrôle exploitable : périmètre, exigences proposées, responsabilités, état initial du produit, corrections du rapport source et preuves à recueillir. Il prépare les arbitrages du responsable sécurité, du produit et du client.

Élément	État de cette version
Référence technique	Commit f0fe7c89fbe28e23e0b80b828f3cc81de316f681. Arbre Git propre au début de la revue.
Date et méthode	8 octobre 2026. Lecture ciblée du code, des issues et de sources primaires publiques. Aucune inspection du site ni exécution de tests OT.
Périmètre de travail	France / Union européenne ; site tertiaire type. Hypothèse à confirmer, pas un site identifié.
Statut	Version 0.1 pour revue. Aucune approbation, certification ou conformité juridique acquise.
Dossier associé	AGR-1481 / CYBER-G2 : risques, zones, conduits, objectifs et scénarios de recette.

Décisions prioritaires

Nommer les responsables ; identifier le site et l’entité cliente ; valider les textes et contrats applicables ; obtenir les normes IEC sous licence ; approuver les objectifs de disponibilité. Le registre distingue les contrôles proposés des preuves réellement disponibles.

Les 26 recommandations ANSSI, les sept familles IEC et les dix points de recette du rapport sont couverts. Les cases non évaluées sont conservées explicitement : l’absence de preuve n’est jamais un résultat favorable.

01 / Périmètre et hypothèses

Profil	Périmètre retenu et conséquence
P1 - Référence de travail	Une instance Gridone locale par site, PostgreSQL/TimescaleDB et équipements OT. Accès utilisateurs via un frontal HTTPS maîtrisé ; administration via une chaîne distincte.
P2 - Hérité	P1 avec BACnet/IP, Modbus TCP/RTU ou autres segments non chiffrés. Chaque exception doit identifier un îlot, des opérations permises, un propriétaire et une expiration.
P3 - Connexions externes	Applications tierces, maintenance distante, registry, identité centralisée éventuelle. Aucune confiance implicite ni routage libre vers le terrain.
Développement / démonstration	HTTP ou données en mémoire possibles pour un environnement isolé ; ne constituent pas un profil de production accepté.

Frontière du produit

Inclus : API HTTP et WebSocket, UI et SDK/CLI comme clients, utilisateurs/rôles, applications externes, drivers et imports, automations, commandes, règles d’exploitation, transports, stockage, packaging et chaîne de publication. Les processus concrets et flux sont décrits dans G2.

Frontière du site

Hôte et OS, pare-feux, commutateurs, réseau d’administration, automates, passerelles, PKI, DNS/temps, logs, sauvegardes, postes, accès physiques et procédures d’exploitation. Leur présence n’est pas attestée par le dépôt.

Données et fonctions

Télémétrie, consignes, historiques, topologie et configurations ; comptes, coordonnées, rôles et traces nominatives ; secrets et clés privées. Les données de bâtiment peuvent révéler l’occupation. Classification proposée : données internes sensibles ; secrets à accès strictement limité.

Exclusion de sûreté : le dossier ne qualifie aucune fonction de sécurité incendie, de protection des personnes ou de régulation critique. Si Gridone interagit avec ces fonctions, l’exploitant doit fournir une analyse dédiée et confirmer des protections autonomes indépendantes.

02 / Applicabilité réglementaire

NIS2 - Décision ouverte, par entité

Base : légale conditionnelle. État : non évalué pour les entités concernées.

Qualifier séparément le client et Agrid : activité, taille, pays d'établissement, éventuelle désignation et régime sectoriel. Le fait de superviser un bâtiment ne suffit pas à déterminer l'assujettissement. Examiner la gouvernance, la gestion des risques et les incidents au regard des articles 20, 21 et 23. Le propriétaire du site porte la décision avec son conseil juridique ; Agrid fournit les éléments produit. [S2-S4]

État français observé le 08/10/2026

La page ANSSI consultée présente encore la transposition et ReCyF comme document de travail ; le dossier de l'Assemblée consulté présente une première lecture. Ces pages ne constituent pas une preuve exhaustive du droit en vigueur. Aucune référence de loi française de transposition promulguée n'a été établie dans cette revue. Faire confirmer le texte au Journal officiel, les décrets, les dates et l'assujettissement avant de contractualiser. [S3-S4]

Incidents : qualification avant notification

Prévoir une procédure de qualification d'incident important et une chaîne d'escalade. Le cadre européen prévoit notamment alerte précoce sous 24 h, notification sous 72 h et rapport final normalement sous un mois après la notification ; cas particuliers et règles nationales à vérifier. Une panne CVC n'est pas automatiquement un incident notifiable. Le délai de connaissance et la décision doivent être tracés. [S2, S5]

Autres examens nécessaires

CRA : faire qualifier Gridone et le rôle d'Agrid au regard des modalités de mise sur le marché. L'ANSSI indique des notifications dès septembre 2026 et une application générale en décembre 2027 ; revue prioritaire à la date du dossier. [S6]
Données personnelles : faire qualifier comptes et traces, finalités, durées, sous-traitants et droits avec le responsable données ; analyse juridique détaillée hors de cette revue.
Contrat : aucun CCTP, SLA ou engagement client signé n'a été fourni.

03 / Références et familles IEC

Les fiches publiques IEC permettent de vérifier les éditions et leur objet. Les textes normatifs complets sous licence n'ont pas été consultés. Aucune clause SR/CR ni exigence additionnelle n'est déclarée vérifiée ; le rapprochement ci-dessous est une proposition de travail, à compléter par le spécialiste normes. [S7-S11]

Référence candidate	Usage dans le périmètre
IEC 62443-4-1:2018	Processus de développement et maintenance du produit Agrid.
IEC 62443-4-2:2019 + COR1:2022	Capacités des composants retenus ; type de composant et clauses à qualifier.
IEC 62443-3-2:2020	Périmètre système, zones/conduits, appréciation des risques et cibles de sécurité.
IEC 62443-3-3:2013 + corrigendum 2014	Exigences du système intégré et justification des niveaux visés.
IEC 62443-2-4:2023	Processus de l'intégrateur et du prestataire de maintenance.

Famille	Disposition proposée / contrôles / pilote
FR1 - Identifier et authentifier	B01-B02 ; produit et responsable identité client.
FR2 - Maîtriser les usages	B03-B04 ; produit et exploitant.
FR3 - Préserver l'intégrité	B07, B09, B11, B14 ; produit et intégrateur.
FR4 - Protéger la confidentialité	B05-B06, B10 ; produit et RSSI client.
FR5 - Restreindre les flux	B08-B10 et ANSSI R2-R7 ; intégrateur.
FR6 - Détecter et traiter les événements	B12, B16 ; sécurité Agrid et RSSI client.
FR7 - Préserver la disponibilité	B13-B15 et ANSSI R8 ; exploitant et intégrateur.

Niveau de sécurité : SL-T 2 constitue seulement une hypothèse de conception de G2, par zone et famille. Le niveau cible, les capacités du produit et le niveau atteint sont trois notions distinctes. Aucun certificat IEC n'est établi.

04 / Responsabilités proposées

R = réalise ; A = valide et répond du résultat ; C = consulté ; I = informé. Un rôle A par ligne. Ce RACI propose une répartition de travail et ne remplace pas le contrat. Si Agrid cumule plusieurs rôles, les décisions produit et site restent distinctes.

Activité	A	R	C / I
Applicabilité client, droit, contrat	Client	RSSI + juriste client	Sécurité Agrid, intégrateur
Exigences du produit et processus IEC 4-1	Produit Agrid	Ingénierie Agrid	Sécurité Agrid / intégrateur
Validation du registre G1	Sécurité Agrid	Architecte Agrid	RSSI + juriste client
Risques physiques et limites de fonctionnement	Exploitant	Ingénieur OT	Intégrateur, architecte
Architecture site, zones, filtrage	RSSI client	Intégrateur	Exploitant, architecte
Identités et accès maintenance du site	RSSI client	Exploitant / intégrateur	Sécurité Agrid
Secrets, API, autorisations produit	Produit Agrid	Ingénierie Agrid	Sécurité Agrid
Versions / durcissement automates	Intégrateur	Intégrateur + fournisseur	Exploitant
Correctifs produit, SBOM, avis	Produit Agrid	Ingénierie + sécurité Agrid	Intégrateur / client
Sauvegardes et reprise du site	Exploitant	Intégrateur	Produit Agrid
Qualification et notification d’incident client	Client	RSSI + juriste client	Agrid, intégrateur
Acceptation des risques résiduels du site	Client	RSSI + exploitant	Sécurité Agrid, intégrateur
Recette et admission sur site	Exploitant	Intégrateur + évaluateur	RSSI client, Agrid

Les titulaires nominatifs et leurs suppléants restent à désigner. Le fournisseur matériel apporte les versions supportées, procédures et preuves d’intégrité ; sa déclaration ne vaut pas validation de l’intégration. Le client ne peut déléguer implicitement toutes ses obligations au produit.

05 / État initial du produit (1/3)

Constats limités aux fichiers cités, au commit de référence. Lecture de code, sans validation dynamique.

C01 - Mots de passe et bootstrap

packages/users/src/users/validation.py
packages/users/src/users/password.py

bcrypt présent ; longueur minimale définie à 5 caractères. Mot de passe administrateur initial fourni par configuration. Politique robuste et résistance aux essais à qualifier. Statut : partiel.

C02 - Sessions HTTP

packages/users/src/users/auth.py
packages/api/src/api/routes/users/auth_router.py

JWT access / refresh ; durées par défaut 30 minutes / 7 jours. Logout supprime les cookies ; refresh génère un nouveau jeton sans registre de révocation observé dans ces chemins. Statut : partiel.

C03 - WebSocket et rôles

packages/api/src/api/auth.py
packages/api/src/api/routes/websocket.py

Authentification bearer explicite, sans repli cookie ; connexion bornée par l’expiration du jeton. Filtrage du flux selon rôle à l’ouverture ; révocation immédiate d’une connexion ouverte non établie. Statut : partiel.

C04 - Confidentialité des secrets

packages/devices_manager/src/devices_manager/storage/transport_record.py
packages/devices_manager/src/devices_manager/dto/transport_dto.py

Persistance de la configuration transport par model_dump ; masquage DTO fondé sur le marqueur secret. La clé privée MQTT n’a pas ce marqueur. Chiffrement applicatif de la configuration non identifié sur ces chemins. Statut : manquant pour cette protection.

C05 - Modes de transport

packages/devices_manager/src/devices_manager/core/transports/mqtt_transport/transport_config.py

MQTT : TLS optionnel, tls=False et port 1883 par défaut ; option tls_insecure présente. Capacités TLS et certificats ne prouvent pas leur activation ni les ACL du broker. Statut : partiel.

C06 - Confiance OPC-UA

packages/devices_manager/src/devices_manager/core/transports/opcua_transport/security.py

Certificat serveur enregistré automatiquement à la première connexion ; changement ultérieur rejeté. La découverte initiale utilise un canal non sécurisé. Provisionnement de confiance indépendant nécessaire. Statut : partiel.

05 / État initial du produit (2/3)

Constats limités aux fichiers cités, au commit de référence. Lecture de code, sans validation dynamique.

C07 - Image et privilèges

docker/Dockerfile
docker/supervisord.conf

Dockerfile sans directive USER ; supervisord et uvicorn sans changement d'utilisateur explicite dans la configuration lue. Un déploiement peut surcharger l'utilisateur : configuration effective non inspectée. Statut : manquant dans l'image de référence.

C08 - Frontière HTTPS

docker/README.md
docker/nginx.conf.template

nginx interne en HTTP sur 8765 ; backend sur 127.0.0.1:8000. La documentation de production prévoit un proxy HTTPS et NGINX_BIND_ADDRESS=127.0.0.1 en mode host. Configuration réelle du proxy non évaluée.

C09 - Ingress public

packages/api/src/api/routes/transports_router.py
packages/devices_manager/src/devices_manager/core/transports/webhook_transport/auth.py

Route sans JWT, authentification au niveau du transport ; bearer par défaut, HMAC disponible, mode none autorisé. Corps borné à 1 Mio. La vérification HMAC lue n'impose ni nonce ni date anti-rejeu. Statut : partiel.

C10 - Requêtes sortantes

packages/devices_manager/src/devices_manager/core/transports/http_transport/client.py
packages/apps/src/apps/apps_manager.py

Client HTTP vers les adresses du driver ; proxy des applications vers leur api_url. Liste d'autorisation réseau et protection anti-SSRF non observées dans ces chemins. Leur absence sur tout le déploiement n'est pas démontrée.

C11 - Garde et historique des commandes

packages/commands/src/commands/service.py
packages/api/src/api/selection_commands.py

Service de commandes et garde de règles d'exploitation présents. Prévisualisation liée à l'utilisateur, à la configuration et à une durée, puis consommation unique. Preuve de sûreté physique ou d'audit exhaustif non établie. Statut : partiel.

05 / État initial du produit (3/3)

Constats limités aux fichiers cités, au commit de référence. Lecture de code, sans validation dynamique.

C12 - Imports et parsing

packages/models/src/models/yaml_loader.py
packages/devices_manager/src/devices_manager/core/presentation/package.py

Chargeur YAML borné et contrôles de paquets de présentation présents. Ces barrières de parsing ne prouvent ni la provenance des drivers ni l'innocuité d'une adresse de commande modifiée. Statut : partiel.

C13 - Publication des images

.github/workflows/release.yml

Pipeline de publication conditionné à une suite d'acceptation puis signature cosign du digest. Vérification obligatoire côté déploiement et exercice de rollback non établis. Aucun run CI relancé pour cette revue. Statut : partiel.

C14 - Applications externes

packages/api/src/api/routes/apps/registration_router.py
packages/apps/src/apps/registration_service.py

Dépôt d'une demande d'enregistrement sans JWT ; validation des demandes soumise à permissions. Compte de service et appels vers l'URL de l'application. Quotas, expiration et réduction des droits à qualifier. Statut : partiel.

C15 - Autorisations

packages/api/src/api/auth.py
packages/api/src/api/access/policy.py

Dépendances de permissions et projection des lectures par rôle présentes. Le rôle porté par le jeton et la définition actuelle du rôle doivent être distingués ; changement de rôle utilisateur et flux ouverts à tester. Statut : partiel.

C16 - Mesures et disponibilité

packages/devices_manager/src/devices_manager/core/device/trust_expiry.py
packages/operating_rules/src/operating_rules/guard.py

Expiration de confiance dans les observations et règles avec max_age_seconds présentes. Durées acceptables par fonction, comportement électrique/automate, restauration et niveaux de charge du site non évalués.

06 / Registre ANSSI (1/5)

26 recommandations, avec les alternatives R3-, R6- et R22- ; aucune non-applicabilité site approuvée.

Source exacte : ANSSI-PA-110 v1.0 du 27/04/2026 [S1], pages imprimées indiquées. Base : recommandation, contractualisation à décider. N1/N2 expriment l'horizon de mise en œuvre. INT = intégrateur ; OPS = exploitant. Chaque rôle reste à nommer. Statut site : **non évalué** pour chaque ligne ; résiduel : non accepté.

R1 / Poste d'ingénierie dédié

N1 ; p. 8 ; responsable INT ; AGR-1510

Inventorier et durcir le poste ; interdire Web/messagerie et vérifier ses accès.
Vérification / preuve attendue : Configuration du poste + essai d'accès contrôlé. Dossier prévu E/ANSSI-R1.
Applicabilité : retenue pour le site type ; hors périmètre du code seul. Risque lié : RK12.

R2 / Réseau d'administration séparé

N1 ; p. 8 ; responsable INT ; AGR-1508

Définir un réseau et un filtrage d'administration distincts du métier.
Vérification / preuve attendue : Schéma + export règles + test interzone. Dossier prévu E/ANSSI-R2.
Applicabilité : retenue pour le site type ; hors périmètre du code seul. Risque lié : RK08.

R3 / Administration protégée

N1 ; p. 8-9 ; responsable INT ; AGR-1509

Protocoles chiffrés et authentifiés ; R3- : tunnel IPsec au plus près si l'outil est insuffisant.
Vérification / preuve attendue : Profil de tunnel + contrôle d'identité et refus. Dossier prévu E/ANSSI-R3.
Applicabilité : retenue pour le site type ; hors périmètre du code seul. Risque lié : RK01.

R4 / Cloisonnement de la GTB

N1 ; p. 9 ; responsable INT ; AGR-1508

Séparer GTB et autres SI, puis les fonctions techniques ; aucun pont non filtré.
Vérification / preuve attendue : Plan VLAN + routes + observation des flux. Dossier prévu E/ANSSI-R4.
Applicabilité : retenue pour le site type ; hors périmètre du code seul. Risque lié : RK08.

R5 / Filtrage inter-VLAN

N2 ; p. 9 ; responsable INT ; AGR-1508

Autoriser seulement les flux métier identifiés dans les conduits de G2.
Vérification / preuve attendue : Matrice de flux + tests permis/interdits. Dossier prévu E/ANSSI-R5.
Applicabilité : retenue pour le site type ; hors périmètre du code seul. Risque lié : RK08.

R6 / Accès distant via VPN

N1 ; p. 10 ; responsable INT ; AGR-1509

VPN IPsec et authentification robuste ; R6- : VPN TLS 1.3 en alternative. Bastion pour les accès prestataires.
Vérification / preuve attendue : Connexion nominative + retrait des droits. Dossier prévu E/ANSSI-R6.
Applicabilité : retenue pour le site type ; hors périmètre du code seul. Risque lié : RK01.

06 / Registre ANSSI (2/5)

26 recommandations, avec les alternatives R3-, R6- et R22- ; aucune non-applicabilité site approuvée.

Source exacte : ANSSI-PA-110 v1.0 du 27/04/2026 [S1], pages imprimées indiquées. Base : recommandation, contractualisation à décider. N1/N2 expriment l'horizon de mise en œuvre. INT = intégrateur ; OPS = exploitant. Chaque rôle reste à nommer. Statut site : **non évalué** pour chaque ligne ; résiduel : non accepté.

R7 / BACnet Foreign Device

N1 ; p. 10 ; responsable INT ; AGR-1498

Si BACnet/IP présent, désactiver Foreign Device et filtrer les services associés ; analyser tout besoin incompatible.
Vérification / preuve attendue : Export BBMD/FD + essai isolé. Dossier prévu E/ANSSI-R7.
Applicabilité : conditionnelle à l'équipement ou à l'usage cité ; hors périmètre produit seul, décision site ouverte. Risque lié : RK07.

R8 / Disponibilité du réseau

N1 ; p. 10 ; responsable INT ; AGR-1508

Justifier redondance des liens et équipements selon l'analyse des fonctions.
Vérification / preuve attendue : Architecture + essai de perte d'un élément. Dossier prévu E/ANSSI-R8.
Applicabilité : retenue pour le site type ; hors périmètre du code seul. Risque lié : RK16.

R9 / Prises et ports inutilisés

N1 ; p. 10 ; responsable INT ; AGR-1510

Placer les prises publiques dans un VLAN d'accueil ; ports inutilisés désactivés et en quarantaine.
Vérification / preuve attendue : Inventaire ports + contrôle de raccordement. Dossier prévu E/ANSSI-R9.
Applicabilité : retenue pour le site type ; hors périmètre du code seul. Risque lié : RK12.

R10 / Durcissement des commutateurs

N1 ; p. 11 ; responsable INT ; AGR-1510

Réduire les services, sécuriser le management et maîtriser la configuration.
Vérification / preuve attendue : Configuration datée + comparaison du référentiel. Dossier prévu E/ANSSI-R10.
Applicabilité : retenue pour le site type ; hors périmètre du code seul. Risque lié : RK08.

R11 / Isolation par PVLAN

N2 ; p. 11 ; responsable INT ; AGR-1508

Évaluer le mode isolé contre les communications latérales ; conserver les échanges métier nécessaires.
Vérification / preuve attendue : Justification + matrice de communications locales. Dossier prévu E/ANSSI-R11.
Applicabilité : retenue pour le site type ; hors périmètre du code seul. Risque lié : RK08.

06 / Registre ANSSI (3/5)

26 recommandations, avec les alternatives R3-, R6- et R22- ; aucune non-applicabilité site approuvée.

Source exacte : ANSSI-PA-110 v1.0 du 27/04/2026 [S1], pages imprimées indiquées. Base : recommandation, contractualisation à décider. N1/N2 expriment l'horizon de mise en œuvre. INT = intégrateur ; OPS = exploitant. Chaque rôle reste à nommer. Statut site : **non évalué** pour chaque ligne ; résiduel : non accepté.

R12 / Passerelles protocolaires

N1 ; p. 11 ; responsable INT ; AGR-1511

Recenser versions/support, appliquer les correctifs et couper les services inutiles.
Vérification / preuve attendue : Versions + avis fournisseur + configuration. Dossier prévu E/ANSSI-R12.
Applicabilité : retenue pour le site type ; hors périmètre du code seul. Risque lié : RK07.

R13 / Synchronisation horaire

N1 ; p. 11 ; responsable OPS ; AGR-1503

Préférer une source fiable commune et NTPv4 disponible ; vérifier la dérive et les sources.
Vérification / preuve attendue : Configuration temps + mesure de décalage. Dossier prévu E/ANSSI-R13.
Applicabilité : retenue pour le site type ; hors périmètre du code seul. Risque lié : RK13.

R14 / Intégrité logiciel / automate

N1 ; p. 12 ; responsable INT ; AGR-1511

Contrôler périodiquement outils d'ingénierie, firmware et configuration.
Vérification / preuve attendue : Empreintes / mécanisme fournisseur + contrôle. Dossier prévu E/ANSSI-R14.
Applicabilité : retenue pour le site type ; hors périmètre du code seul. Risque lié : RK06.

R15 / Mots de passe des automates

N1 ; p. 12 ; responsable INT ; AGR-1511

Protéger programme, application, firmware et carte mémoire ; remplacer les valeurs initiales.
Vérification / preuve attendue : Configuration expurgée + refus d'opérations. Dossier prévu E/ANSSI-R15.
Applicabilité : retenue pour le site type ; hors périmètre du code seul. Risque lié : RK01.

R16 / Services automates inutilisés

N1 ; p. 13 ; responsable INT ; AGR-1511

Désactiver les services inutiles ; encadrer toute réactivation de maintenance.
Vérification / preuve attendue : Liste de services + contrôle passif / banc. Dossier prévu E/ANSSI-R16.
Applicabilité : retenue pour le site type ; hors périmètre du code seul. Risque lié : RK07.

06 / Registre ANSSI (4/5)

26 recommandations, avec les alternatives R3-, R6- et R22- ; aucune non-applicabilité site approuvée.

Source exacte : ANSSI-PA-110 v1.0 du 27/04/2026 [S1], pages imprimées indiquées. Base : recommandation, contractualisation à décider. N1/N2 expriment l'horizon de mise en œuvre. INT = intégrateur ; OPS = exploitant. Chaque rôle reste à nommer. Statut site : **non évalué** pour chaque ligne ; résiduel : non accepté.

R17 / Listes d'accès IP

N2 ; p. 13 ; responsable INT ; AGR-1498

Activer les ACL natives disponibles pour limiter les interlocuteurs légitimes.
Vérification / preuve attendue : ACL automate + cas permis et refusés. Dossier prévu E/ANSSI-R17.
Applicabilité : retenue pour le site type ; hors périmètre du code seul. Risque lié : RK07.

R18 / Journalisation des équipements

N2 ; p. 13 ; responsable OPS ; AGR-1503

Activer les traces disponibles et leur collecte protégée ; signaler les limites matérielles.
Vérification / preuve attendue : Événement de test corrélé au collecteur. Dossier prévu E/ANSSI-R18.
Applicabilité : retenue pour le site type ; hors périmètre du code seul. Risque lié : RK13.

R19 / USB inutilisés

N1 ; p. 13 ; responsable INT ; AGR-1510

Bloquer les ports et désactiver le démarrage USB lorsque possible.
Vérification / preuve attendue : Configuration / contrôle physique. Dossier prévu E/ANSSI-R19.
Applicabilité : retenue pour le site type ; hors périmètre du code seul. Risque lié : RK12.

R20 / BIOS / UEFI

N2 ; p. 13-14 ; responsable INT ; AGR-1510

Protéger l'accès aux réglages du poste/hôte ; inventorier les exceptions.
Vérification / preuve attendue : Configuration expurgée + contrôle d'accès. Dossier prévu E/ANSSI-R20.
Applicabilité : retenue pour le site type ; hors périmètre du code seul. Risque lié : RK12.

R21 / Sas de médias amovibles

N1 ; p. 14 ; responsable OPS ; AGR-1510

Si médias utilisés, organiser un sas ou une station blanche maintenue.
Vérification / preuve attendue : Procédure + passage d'un média d'essai. Dossier prévu E/ANSSI-R21.
Applicabilité : conditionnelle à l'équipement ou à l'usage cité ; hors périmètre produit seul, décision site ouverte. Risque lié : RK12.

06 / Registre ANSSI (5/5)

26 recommandations, avec les alternatives R3-, R6- et R22- ; aucune non-applicabilité site approuvée.

Source exacte : ANSSI-PA-110 v1.0 du 27/04/2026 [S1], pages imprimées indiquées. Base : recommandation, contractualisation à décider. N1/N2 expriment l'horizon de mise en œuvre. INT = intégrateur ; OPS = exploitant. Chaque rôle reste à nommer. Statut site : **non évalué** pour chaque ligne ; résiduel : non accepté.

R22 / Communications radio

N1 ; p. 14 ; responsable INT ; AGR-1495

Sélectionner des protections adaptées ; R22- : exception limitée aux capteurs non sensibles, avec justification.
Vérification / preuve attendue : Inventaire radio + profil + analyse de conséquence. Dossier prévu E/ANSSI-R22.
Applicabilité : conditionnelle à l'équipement ou à l'usage cité ; hors périmètre produit seul, décision site ouverte. Risque lié : RK09.

R23 / Protection Wi-Fi

N2 ; p. 15 ; responsable INT ; AGR-1510

Si Wi-Fi présent, vérifier chiffrement robuste et authentification entreprise conformément au guide.
Vérification / preuve attendue : Export paramètres + essai de refus. Dossier prévu E/ANSSI-R23.
Applicabilité : conditionnelle à l'équipement ou à l'usage cité ; hors périmètre produit seul, décision site ouverte. Risque lié : RK09.

R24 / Liaison automate-supervision

N1 ; p. 15 ; responsable INT ; AGR-1495

Qualifier les modes sécurisés réellement activés, ou traiter l'écart hérité.
Vérification / preuve attendue : Profil transport + capture / négociation. Dossier prévu E/ANSSI-R24.
Applicabilité : retenue pour le site type ; hors périmètre du code seul. Risque lié : RK07.

R25 / Entrées/sorties déportées

N2 ; p. 15 ; responsable INT ; AGR-1511

Si E/S distantes, vérifier les protections de bout en bout ; le tunnel amont ne protège pas le bus aval.
Vérification / preuve attendue : Schéma physique + preuves fournisseur / essais. Dossier prévu E/ANSSI-R25.
Applicabilité : conditionnelle à l'équipement ou à l'usage cité ; hors périmètre produit seul, décision site ouverte. Risque lié : RK09.

R26 / Modbus et BACnet hérités

N1 ; p. 15 + ann. A/B ; responsable INT ; AGR-1498

Appliquer les mesures des annexes au contexte ; distinguer écritures métier, administration et découverte.
Vérification / preuve attendue : Règles applicatives + tests positifs/négatifs sur banc. Dossier prévu E/ANSSI-R26.
Applicabilité : conditionnelle à l'équipement ou à l'usage cité ; hors périmètre produit seul, décision site ouverte. Risque lié : RK07.

07 / Contrôles produit et transverses (1/4)

Base : politique de sécurité proposée, complétée par les références indiquées ; législation conditionnelle à l'assujettissement et normes conditionnelles au périmètre approuvé. Applicabilité : retenue pour P1, adaptations P2/P3 selon site. PROD = produit Agrid ; SEC = sécurité Agrid. Chaque contrôle conserve un risque résiduel **non accepté**.

B01 / Identités et secrets humains

FR1 ; S2 art.21(2)(i),(j), clauses IEC à confirmer | R : PROD / RSSI | État : Partiel C01
AGR-1483 ; AGR-1485

Comptes nominatifs, MFA privilégié et protection contre les essais ; définir politique de mots de passe et secours local.
Test : Essais de refus, accès MFA, récupération et comptes initiaux.
Preuve attendue : E/B01 (résultats, version, configuration) ; risques RK01.

B02 / Sessions et révocation

FR1-FR2 ; politique proposée | R : PROD | État : Partiel C02-C03
AGR-1484

Rotation à usage unique des refresh, retrait de sessions HTTP/WS, expiration d'inactivité selon cible G2.
Test : Réutiliser un jeton retiré et observer une connexion WS ouverte.
Preuve attendue : E/B02 (résultats, version, configuration) ; risques RK02.

B03 / Autorisations et séparation des rôles

FR2 ; S2 art.21(2)(i) | R : PROD / RSSI | État : Partiel C15
AGR-1487

Couvrir lectures, mutations, lots, imports, règles et automations. Les droits serveur font foi.
Test : Matrice centralisée d'autorisations : refus inter-rôles et réduction des droits.
Preuve attendue : E/B03 (résultats, version, configuration) ; risques RK03.

B04 / Comptes de service et maintenance

FR2 ; politique proposée | R : PROD / INT | État : Partiel C14
AGR-1486 ; AGR-1509

Accès bornés par fonction et durée, titulaire et révocation ; validation explicite du manifeste externe.
Test : Fin d'intervention, expiration, demande usurpée et compte trop privilégié.
Preuve attendue : E/B04 (résultats, version, configuration) ; risques RK03.

07 / Contrôles produit et transverses (2/4)

Base : politique de sécurité proposée, complétée par les références indiquées ; législation conditionnelle à l'assujettissement et normes conditionnelles au périmètre approuvé. Applicabilité : retenue pour P1, adaptations P2/P3 selon site. PROD = produit Agrid ; SEC = sécurité Agrid. Chaque contrôle conserve un risque résiduel **non accepté**.

B05 / Stockage et cycle de vie des secrets

FR4 ; S2 art.21(2)(h) | R : PROD | État : Manquant C04
AGR-1488

Chiffrement approprié, séparation des clés, rotation, migration et récupération ; aucun secret dans l'export/API.
Test : Canaris de secrets dans lecture, export, logs et sauvegarde ; rotation/restauration.
Preuve attendue : E/B05 (résultats, version, configuration) ; risques RK04.

B06 / Certificats et confiance

FR1-FR4 ; politique proposée | R : PROD / INT | État : Partiel C05-C06
AGR-1489 ; AGR-1501

Provisionner la confiance hors canal, inventorier les certificats, renouveler avant échéance et rejeter les imposteurs.
Test : Certificat inattendu/expiré et renouvellement sans rupture hors fenêtre.
Preuve attendue : E/B06 (résultats, version, configuration) ; risques RK05.

B07 / Image et hôte de production

FR3 ; politique proposée | R : PROD / INT | État : Manquant image C07
AGR-1490

Exécution sans privilèges inutiles, droits fichiers limités, volumes documentés ; contrôler le conteneur réellement lancé.
Test : UID effectif, capacités, accès refusés et santé nominale des transports.
Preuve attendue : E/B07 (résultats, version, configuration) ; risques RK08.

B08 / Entrée HTTPS et réseau

FR5 ; ANSSI R2-R6 ; FR4 | R : INT | État : Partiel C08
AGR-1491 ; AGR-1508

Frontal HTTPS approuvé ; pas d'exposition HTTP du port 8765 en réseau host ; filtrage par conduit.
Test : Inspection de binding et règles, accès permis/refusés, certificat et cookie.
Preuve attendue : E/B08 (résultats, version, configuration) ; risques RK08.

07 / Contrôles produit et transverses (3/4)

Base : politique de sécurité proposée, complétée par les références indiquées ; législation conditionnelle à l'assujettissement et normes conditionnelles au périmètre approuvé. Applicabilité : retenue pour P1, adaptations P2/P3 selon site. PROD = produit Agrid ; SEC = sécurité Agrid. Chaque contrôle conserve un risque résiduel **non accepté**.

B09 / Sorties et ingress non interactifs

FR3-FR5 ; politique proposée | R : PROD / INT | État : Partiel C09-C10
AGR-1493 ; AGR-1494

Limiter destinations et résolutions ; authentifier chaque push, anti-rejeu, quotas ; isoler l'enregistrement public.
Test : Destination interdite, résolution changeante, push rejoué et corps excessif.
Preuve attendue : E/B09 (résultats, version, configuration) ; risques RK10,RK11.

B10 / Sécurité des transports terrain

FR4-FR5 ; ANSSI R22-R26 | R : PROD / INT | État : Partiel C05-C06
AGR-1495 ; AGR-1496 ; AGR-1497 ; AGR-1498 ; AGR-1499 ; AGR-1500 ; AGR-1501

Profil sûr validé pour chaque transport ou exception héritée limitée ; inclure le segment après la passerelle.
Test : Négociation, refus d'un mode dégradé, ACL métier et commandes autorisées.
Preuve attendue : E/B10 (résultats, version, configuration) ; risques RK05,RK07,RK09.

B11 / Intégrité des commandes et configurations

FR3 ; ANSSI R14 | R : PROD / OPS | État : Partiel C11-C12
AGR-1504 ; AGR-1507

Versionner drivers et règles, tracer approbations ; revalider les écritures et la fraîcheur au moment d'agir.
Test : Changement de driver/règle entre preview et action, import malformé, valeur périmée.
Preuve attendue : E/B11 (résultats, version, configuration) ; risques RK06,RK09,RK17.

B12 / Audit et temps

FR6 ; ANSSI R13,R18 | R : PROD / OPS | État : Partiel C11 ; site non évalué
AGR-1502 ; AGR-1503

Tracer acteur, opération, avant/après, refus, horodatage et corrélation ; export protégé et alerte de rupture.
Test : Reconstituer une séquence d'actions ; altération/perte de collecte et dérive de temps.
Preuve attendue : E/B12 (résultats, version, configuration) ; risques RK13.

07 / Contrôles produit et transverses (4/4)

Base : politique de sécurité proposée, complétée par les références indiquées ; législation conditionnelle à l'assujettissement et normes conditionnelles au périmètre approuvé. Applicabilité : retenue pour P1, adaptations P2/P3 selon site. PROD = produit Agrid ; SEC = sécurité Agrid. Chaque contrôle conserve un risque résiduel **non accepté**.

B13 / Sauvegarde et restauration

FR7 ; S2 art.21(2)(c) | R : OPS / INT | État : Non évalué
AGR-1505

Sauvegarder données, configuration, clés récupérables, PKI et projets automates ; copie hors ligne, accès séparé.
Test : Restauration complète sur environnement vierge ; mesure RTO/RPO.
Preuve attendue : E/B13 (résultats, version, configuration) ; risques RK14.

B14 / Chaîne logicielle et vulnérabilités

FR3 ; S2 art.21(2)(d),(e) ; S6 | R : PROD | État : Partiel C13
AGR-1512 ; AGR-1513 ; AGR-1514 ; AGR-1515

SBOM, scans et gestion des avis ; vérifier la signature à l'installation ; correctifs qualifiés avec retour arrière.
Test : Image non approuvée refusée, rollback contrôlé et exercice d'avis fournisseur.
Preuve attendue : E/B14 (résultats, version, configuration) ; risques RK15,RK18.

B15 / Continuité et bornage

FR7 ; ANSSI R8 | R : PROD / OPS | État : Partiel C16 ; site non évalué
AGR-1506 ; AGR-1507

Limiter ressources et files ; protéger la régulation autonome ; qualifier coupures réseau, DB, identité et courant.
Test : Charge limitée sur banc et pannes injectées ; aucun rejeu dangereux au retour.
Preuve attendue : E/B15 (résultats, version, configuration) ; risques RK16,RK17,RK20.

B16 / Réponse aux incidents et admission

FR6 ; S2 art.20-23 ; gouvernance proposée | R : RSSI / SEC | État : Non évalué
AGR-1516 ; AGR-1517 ; AGR-1518 ; AGR-1519

Chaîne d'alerte, qualification juridique et exercice ; preuves indépendantes ; signatures et résiduels explicites.
Test : Exercice sur table + campagne isolée + procès-verbal de recette.
Preuve attendue : E/B16 (résultats, version, configuration) ; risques RK13,RK18.

08 / Corrections du rapport source

Rapport initial : « Cybersécurité GTB et OT », pièce jointe de l'issue AGR-1480, relue intégralement. Les corrections ci-dessous remplacent ses formulations dans le présent référentiel. Les affirmations non étayées ne sont pas transformées en obligations.

Sujet du rapport	Correction retenue et source
Numéros ANSSI	R7 = Foreign Device ; R11 = PVLAN ; R12 = passerelles ; R13 = temps ; R14 = intégrité ; R15 = mots de passe automates ; R17 = ACL IP ; R18 = logs. Sauvegardes : ne pas les attribuer à R17. [S1]
Guide « 2025 » dans l'URL	Le PDF consulté porte v1.0, 27/04/2026 ; conserver cette édition, et non déduire l'année du nom de fichier. [S1]
N1 / N2 et caractère obligatoire	Ce sont des horizons de mise en œuvre, pas des niveaux de criticité ni des obligations légales générales. Contractualisation et exceptions à approuver. [S1 p.1,3]
Interdiction de toute écriture Modbus	L'annexe A distingue filtrage et détection selon fonction et contexte. Une interdiction globale peut empêcher la régulation. Valider les opérations métier, y compris les écritures nécessaires. [S1 p.16-17]
NIS2 et panne CVC	L'assujettissement dépend de l'entité ; le signalement vise des incidents importants. Les étapes de notification et les conditions doivent être qualifiées. [S2,S5]
SL-T 2/3 automatique et certification	Le niveau cible résulte de l'analyse par zone ; il ne s'agit ni d'un minimum universel, ni d'un certificat. Les capacités d'un composant ne certifient pas le site. [S7-S10]
Mots de passe, patch 30 jours, audit biennal	Propositions de contrat à arbitrer. Le rapport ne démontre pas qu'elles seraient universellement imposées. Même traitement pour les 15 minutes d'inactivité.
TLS 1.3 partout et bus aval protégé	Le profil doit être validé par protocole et équipement. Un tunnel de passerelle ne protège pas à lui seul le bus en aval ; les exigences du guide VPN ne s'étendent pas automatiquement à tous les protocoles.
Scan / injection sur une GTB réelle	Remplacer l'essai généralisé par preuves de configuration, observations passives et tests isolés. Toute action sur équipement actif exige une procédure d'exploitation validée.
Coffre secret / audit déjà établis	La feuille de route n'est pas une preuve d'implémentation. C04 montre une sérialisation de configuration et un masquage partiel, pas un coffre chiffré. C11 ne prouve pas un audit exhaustif.

09 / Les dix contrôles de recette

C01-C16 désignent les constats du code ; les identifiants RC ci-dessous désignent les dix contrôles du rapport initial. Les numéros ANSSI erronés du rapport sont remplacés par le registre de ce dossier. Statut des dix contrôles : **non exécuté**.

Contrôle / responsable	Critère et preuve de clôture	Liens
RC01 - IT/OT / INT	Conduits autorisés documentés ; tentative non autorisée refusée sans perturber la régulation. Plan et configuration signés.	R2,R4,R5 ; B08 ; AGR-1508
RC02 - Comptes / PROD+INT	Valeurs initiales retirées, identité nominative et politique approuvée ; refus prouvé sur banc.	R15 ; B01 ; AGR-1483,1511
RC03 - Maintenance / INT	MFA, bastion, durée et retrait vérifiés ; session et autorisation corrélées.	R6 ; B04 ; AGR-1509
RC04 - Automates / INT	Opérations d'ingénierie non autorisées refusées ; protections configurées selon matériel.	R14-R17 ; AGR-1511
RC05 - Protocoles / INT	Sécurisation active ou exception bornée ; refus des opérations hors liste, maintien des écritures légitimes.	R7,R24-R26 ; B10 ; AGR-1495,1498
RC06 - Physique / INT	Accès maîtrisés ; prises publiques isolées, ports inutilisés désactivés.	R9,R10 ; AGR-1510
RC07 - Versions / PROD+INT	Inventaire daté, versions/support et avis de vulnérabilité rapprochés ; inconnues signalées.	B14 ; AGR-1482,1511,1515
RC08 - Traces / PROD+OPS	Actions et refus corrélés ; temps fiable ; collecte protégée et alerte de rupture.	R13,R18 ; B12 ; AGR-1502,1503
RC09 - Reprise / OPS	Restauration complète en environnement vierge, clés et automates inclus ; objectifs RTO/RPO respectés.	B13 ; AGR-1505
RC10 - Ingénierie / INT+OPS	Poste dédié, USB maîtrisé et sas testé, exceptions documentées.	R1,R19-R21 ; AGR-1510

Les modalités G2 utilisent le banc d'essai comme premier niveau. Les résultats favorables doivent référencer l'actif, la version, la configuration et la méthode ; une simple capture de l'interface ne remplace pas une preuve de refus ou de restauration.

10 / Arbitrages et suivi

Décision ouverte	Pilote / échéance de décision	Sortie requise
D01 - Site, fonctions et données	Produit + client / avant gel du périmètre	Site nommé, liste des fonctions, flux et exclusions approuvés.
D02 - NIS2, droit français, contrat	RSSI + juriste client / avant engagement de conformité	Avis sourcé : entités, textes, dates, clauses et obligations.
D03 - CRA et responsabilités produit	Sécurité + juriste Agrid / revue prioritaire avant prochaine mise sur le marché	Qualification du produit, notifications applicables et responsable.
D04 - Éditions / clauses IEC	Sécurité Agrid / avant référence normative contractuelle	Accès sous licence, sélection des clauses et justification des exclusions.
D05 - Criticité, SL-T et autonomie	Exploitant + ingénieur OT / avant essais terrain	Fonctions critiques, objectifs par zone et protections indépendantes.
D06 - Politiques chiffrées	RSSI + exploitant / avant plan de recette	Sessions, conservation, correctifs, RTO/RPO et charge approuvés.
D07 - Intégration réelle et héritage	Intégrateur / avant pilote	Configurations, inventaire, preuves fournisseurs et exceptions datées.
D08 - Titulaires et calendrier	Sponsor produit + client / lors de la revue G1	Noms, suppléants, dates convenues et capacité de réalisation.

État : aucune décision ci-dessus n’est signée. Les échéances sont des jalons de passage, pas des dates promises ; D08 doit les convertir en dates. L’absence de personnes désignées et de dates convenues empêche la clôture administrative d’AGR-1480.

Gestion des exceptions

Une exception contient contrôle, actif/version, justification métier, risques liés, mesures compensatoires, validateur, date de début, expiration et condition de retrait. Aucune exception permanente implicite pour un protocole ancien. La réévaluation est déclenchée par un incident, un nouveau transport/app, une topologie modifiée ou une mise à jour majeure.

Statuts

Implémenté : preuves complètes pour le périmètre testé. **Partiel :** protection observée mais couverture insuffisante. **Manquant :** écart constaté dans le périmètre examiné. **Non évalué :** aucune conclusion probante. **Non applicable :** exclusion motivée et approuvée. Aucun contrôle de ce dossier n’est déclaré entièrement validé en production.

11 / Preuves et validation

Les chemins E/... du registre sont des destinations logiques proposées, pas des fichiers de preuves déjà présents. Structure cible : E/<contrôle>/<actif>/<version>/<date>. Chaque preuve doit être liée à une issue et à une configuration de référence.

Champ	Contenu requis
Identification	Contrôle Bxx / ANSSI-Rx / RCxx ; scénario G2 ; actif, site, version, digest, auteur et date.
Méthode	Préconditions, environnement, outil/version, actions exécutées et contraintes de sécurité.
Résultat	Attendu, observé, succès/échec/non exécuté ; logs ou export ; limites et reproductibilité.
Intégrité et accès	Empreinte SHA-256, dépôt de preuve à accès restreint, expurgation des secrets et données inutiles.
Décision	Relecteur, acceptation ou anomalie ; risque résiduel, mesure compensatoire et expiration.

Critères d’acceptation AGR-1480

Critère	État au 08/10/2026
Sept familles IEC et dix contrôles de recette	Couverts par une disposition et un rôle proposé ; pas validés.
26 recommandations ANSSI et non-applicabilité	Revue documentaire effectuée ; conditions recensées. Validation site requise.
Registre signé ; questions avec noms et dates	Non satisfait : D01-D08 ouverts, signataires et calendrier à convenir.
Responsabilités produit / intégrateur / client / matériel	Matrice proposée ; acceptation contractuelle encore requise.

Visa à recueillir

Produit Agrid : identité / date / accord sur le périmètre.
Responsable sécurité Agrid : identité / date / accord sur le registre.
RSSI et conseil juridique client : identité / date / applicabilité et contrat.
Intégrateur et exploitant : identité / date / limites du site et responsabilités.

Conclusion de la revue : le livrable documentaire est constitué pour discussion et exécution. Il ne justifie pas de passer l’issue à Done avant les validations ci-dessus. La prochaine version doit conserver les décisions, motifs, sources et versions de preuve.

12 / Sources et traçabilité (1/2)

Sources consultées le 08/10/2026. Les références de code C01-C16 pointent vers un commit immuable.

S1 / ANSSI-PA-110, v1.0 du 27/04/2026

Ouvrir la source

Guide complet consulté, recommandations R1-R26 et annexes A/B. Licence ouverte Etalab v2.0 ; adaptation par Agrid, sans validation de l'ANSSI.

S2 / Directive (UE) 2022/2555, articles 2-3 et 20-23

Ouvrir la source

Texte repéré dans les résultats EUR-Lex ; accès intégral direct empêché par contrôle JavaScript. Les délais sont corroborés par S5. Contrôle juridique complet restant.

S3 / ANSSI - Directive NIS2

Ouvrir la source

Page consultée le 08/10/2026 ; transposition et ReCyF document de travail.

S4 / Assemblée nationale - Dossier Résilience

Ouvrir la source

Page consultée le 08/10/2026 ; première lecture à l'Assemblée affichée. Vérification Journal officiel requise.

S5 / Commission européenne - FAQ NIS2

Ouvrir la source

Source institutionnelle sur les notifications et le périmètre ; consultée via recherche.

S6 / ANSSI - Cadre réglementaire CRA

Ouvrir la source

Calendrier et rôles institutionnels ; consulté le 08/10/2026. Application à Gridone à qualifier.

S7 / IEC 62443-4-1:2018

Ouvrir la source

Fiche de catalogue publique ; texte complet non consulté.

12 / Sources et traçabilité (2/2)

Sources consultées le 08/10/2026. Les références de code C01-C16 pointent vers un commit immuable.

S8 / IEC 62443-4-2:2019

Ouvrir la source

Fiche publique incluant l’indication du corrigendum 2022 ; texte complet non consulté.

S9 / IEC 62443-3-2:2020

Ouvrir la source

Fiche publique : risques par zones/conduits et cibles ; texte complet non consulté.

S10 / IEC 62443-3-3:2013

Ouvrir la source

Fiche publique : exigences système ; corrigendum 2014 indiqué ; texte complet non consulté.

S11 / IEC 62443-2-4:2023

Ouvrir la source

Édition 2.0 vérifiée dans le catalogue ; texte complet non consulté.

S12 / Issues et feuille de route Cyber Compliance

Ouvrir la source

AGR-1480/1481 et index AGR-1480 à AGR-1519 relus. Baseline historique 977f440 remplacée pour la présente revue par f0fe7c8.

S13 / Rapport source fourni par l’utilisateur

Ouvrir la source

Pièce jointe « Source report - Cybersécurité GTB et OT ». SHA-256 annoncé par la feuille de route : f6575bdb73b20580af27b316df0ce9590a0b231585cdb9b75373f494c824f42f ; empreinte originale non recalculée sur le texte extrait.